Centro de Confianza

Nuestra postura de seguridad y compromiso de cumplimiento

Estado de Cumplimiento

- Cumple con el RGPD — Privacidad de datos
- SOC 2 Tipo II — Meta Q3 2027
- Certificado en Azure — Infraestructura
- ISO 27001 — Planificado para 2028

Cifrado

En Tránsito: Todos los datos en tránsito se cifran con TLS 1.2 o superior. Las conexiones HTTP se redirigen automáticamente a HTTPS.

En Reposo: Los registros de la base de datos y las copias de seguridad se cifran con AES-256. Las claves de cifrado se administran por separado usando Azure Key Vault.

Control de Acceso

- Autenticación: autenticación multifactor (MFA) mediante Microsoft Entra ID (Azure AD)
- Autorización: control de acceso basado en roles (RBAC) aplicado en las capas de aplicación y base de datos
- SSO: inicio de sesión único SAML 2.0 disponible para clientes Enterprise a través de WorkOS
- Gestión de sesiones: las sesiones expiran tras 24 horas de inactividad; se exige reautenticación para operaciones sensibles

Infraestructura y Disponibilidad

- Proveedor de nube principal: Microsoft Azure (certificado para HIPAA, FedRAMP, SOC 2)
- Región física activa: despliegue único en Azure West US 2
- Base de datos: MySQL administrada en Azure con copias de seguridad automáticas
- Cache: Azure Managed Redis (Balanced_B3) con alta disponibilidad habilitada y acceso privado
- Perímetro: Cloudflare como CDN/WAF delante del origen en Azure
- Recuperación ante desastres: copias de seguridad georredundantes; RTO < 4 horas, RPO < 1 hora
- SLA: 99,9% de disponibilidad garantizada para planes pagos (excluye mantenimiento programado)

Auditoría y Monitoreo

- Registros de auditoría: todas las acciones de usuario, llamadas a la API y accesos a datos se registran y conservan durante 7 años
- Monitoreo: monitoreo de seguridad en tiempo real mediante Azure Security Center; alertas ante actividad sospechosa
- Detección de intrusiones: detección y prevención de intrusiones de red habilitada en todos los endpoints

Subencargados

Trabajamos con proveedores líderes de la industria para servicios específicos:

Encargado	Finalidad	Ubicación
Microsoft Azure	Cómputo, almacenamiento, redes e inferencia de IA (Azure OpenAI)	Azure West US 2
Paddle	Procesamiento de pagos	US/UK
WorkOS	Autenticación y SSO	US
Google Gemini AI	Servicios de LLM opcionales	US

Respuesta ante Incidentes

- Tiempo de respuesta: los incidentes de seguridad se investigan dentro de las 2 horas posteriores a su detección
- Notificación: los clientes afectados son notificados dentro de las 72 horas posteriores a la confirmación de una filtración de datos (conforme al Art. 33-34 del RGPD)